

ENTERPRISE PORTAL AUDIT REPORT

Nexus Support Portal — Independent Architecture & Design Review Board

Date: 2026-07-24 | Assumed scale: 50,000+ users | Overall: **4.1 / 10**

Maturity: **Internal Tool** | Production readiness: **2.5 / 10** | Verdict: **DO NOT SHIP**

IBM / Microsoft / Stripe reject first: client-trusted RBAC, unwired Entra, secrets in localStorage.

ENTERPRISE PORTAL AUDIT REPORT

Product: Nexus Support Portal (`nexus-support-portal@0.1.0`)

Repository: `nexus\_support\_V2 - kopia`

Audit date: 2026-07-24

Assumed scale: 50,000+ enterprise users

Review board posture: Independent Architecture & Design Review — defect-first, non-encouraging

Scope reviewed: UI/UX, IA, navigation, accessibility, architecture, security, performance, components, design-system compliance, production readiness.

Primary evidence:

- `package.json` (self-describes as “prototype”)
- `src/components/nexus/NexusPortal.tsx` (~42,905 lines; ~1.6 MB)
- `src/app/globals.css` (~14,173 lines)
- `src/app/layout.tsx`, `src/app/api/` (23 route handlers)
- `src/lib/rbac.ts`, `src/lib/auth/`, `src/components/auth/`
- Scania Tegel `@scania/tegel@^1.59.1`
- Installed but largely unwired: TanStack Query/Table, React Hook Form, Zod

Executive Summary

Nexus Support is a dense Scania-branded governance/support SPA with real integration surface area (Jira, GitLab, Microsoft Graph, SMTP, AI) and a credible industrial visual language (Tegel + Scania navy). It is not a production-ready enterprise portal for 50k users.

The product fails Fortune-500 readiness on three non-negotiable gates:

1. Authorization is theater. Roles are selected in the UI and passed as `?role=admin` / body fields. Server routes largely trust the client. This is disqualifying for SAP/IBM/Microsoft security review.
2. Secrets live in the browser. Integration tokens are persisted to `localStorage` (`nexus-integration-secrets-v1`). Any XSS becomes a credential breach.
3. Architecture is a god object. One client file owns UI, RBAC, integrations, admin, charts, and forms (~43k LOC). Maintainability, testability, and release risk are unacceptable at enterprise scale.

Visual maturity is above a typical hackathon demo because Tegel and Scania tokens create brand coherence. Structural maturity remains Internal Tool / Startup MVP. Auth code exists (`AuthProvider`, `AuthGate`, MSAL, ALB OIDC) but is not mounted in `layout.tsx`. There is no `/login` route despite redirects to it. TanStack Query/Table and RHF/Zod are installed and unused—signaling unfinished platformization.

Verdict: Do not ship to 50k users. Treat as a domain prototype with strong Scania chrome and weak enterprise foundations. Security and architecture remediation must precede visual polish.

Overall Score

Category	Score (1–10)	Target	Gap
Visual Design	6.0	8.5	–2.5
UX	5.0	8.5	–3.5
UI	5.5	8.5	–3.0
Navigation	5.5	8.5	–3.0
Information Architecture	4.5	8.5	–4.0
Accessibility	5.0	9.0	–4.0

Category	Score (1–10)	Target	Gap
Performance	3.5	8.5	–5.0
Architecture	3.0	9.0	–6.0
Security	2.0	9.5	–7.5
Maintainability	2.5	8.5	–6.0
Scalability	3.0	9.0	–6.0
Code Quality	3.5	8.5	–5.0
Enterprise Feeling	5.5	9.0	–3.5
Modern Feeling	5.0	8.5	–3.5
Production Readiness	2.5	9.0	–6.5
Weighted overall	4.1 / 10	8.8	–4.7

Security, architecture, and production readiness dominate the weighted score. Cosmetic improvements cannot raise production readiness without those gates.

Maturity Level

Chosen level (ONLY ONE): Internal Tool

Candidate	Why rejected / accepted
Prototype	Too much real domain surface (admin, Jira, escalations, workflows).
Proof of Concept	Exceeds PoC feature breadth.
Internal Tool	Selected. Usable by a known team with trusted network assumptions; auth optional; role switching for demo; SQLite; secrets in browser; package.json says prototype.
Startup MVP	Would require working auth gate, URL IA, and non-spoofable RBAC.
Scale-up Product	Fails multi-tenant ops, observability, CI test depth.
Enterprise Product	Fails security, a11y rigor, IA deep-linking, server authz.
World Class Enterprise Product	Not remotely applicable.

Enterprise Readiness

Not ready. Blocking gates:

Gate	Status	Evidence
Enforced authentication	FAIL	`AuthProvider`/`AuthGate` unused in `layout.tsx`; no `/login` page
Server-side authorization	FAIL	Client `role` query/body trusted on tickets/database
Secret management	FAIL	Jira/GitLab/SMTP tokens in `localStorage`
Security headers	FAIL	`next.config.ts` has no CSP/HSTS/frame-ancestors
Horizontal scale data plane	FAIL	Local SQLite (`node:sqlite`), not enterprise HA store
Module code-split	FAIL	Entire portal is one client tree
Automated regression suite	FAIL	One Playwright a11y smoke; no unit/integration tests
Auditability of privileged actions	PARTIAL	Audit UI exists; server authz for audit trail incomplete
i18n completeness	FAIL	Shell en/sv; most admin/Jira/escalation copy hard-coded EN
Dark mode / forced-colors	FAIL	`colorScheme: "light"` only

Gate	Status	Evidence
Unauthenticated wallboard	FAIL	`tv` reads DB with no auth
Would this belong to IBM / Microsoft / SAP / Stripe / Vercel / Atlassian / Amazon / Google / Volvo / Scania as a shipped product?		
Company	Belongs?	Why
Scania (brand chrome)	Partially	Tegel + Scania Sans + navy is correct. Product governance is not.
Volvo / industrial OEM portal	No	Would require Entra SSO, server RBAC, SOC2-grade secret handling.
IBM	No	Carbon apps do not ship client-trusted admin APIs or 43k-LOC god components.
Microsoft	No	Fluent + Entra patterns require wired MSAL, Conditional Access, Graph least-privilege.
SAP Fiori	No	Fiori Launchpad expects intents/semantic objects, not in-memory module switches.
Stripe	No	Stripe-grade clarity, form validation, and API auth discipline absent.
Vercel	No	App Router used as SPA shell; no route-level architecture.
Atlassian	No	Ticket density without URL state, filters-as-query, or table virtualization.
Amazon	No	Fails operational excellence (observability, blast-radius isolation).
Google	No	Material density/motion/a11y rigor not met.

Closest honest label: Scania-skinned internal governance console, not a Fortune-500 portal.

UI Review

What works

- Scania Tegel header/sidebar create immediate OEM credibility (vs generic shadcn purple demos).
- Dense dashboard aesthetic matches `MASTER.md` Density 8/10 intent.
- Sharp radius (`--radius: 0`) is consistent with industrial brand—not startup soft-UI.

What fails

1. Brand lockup instability

Header brand recently mixed text-image, icon crop, and clipping. Header height 56px cannot host oversized marks.

Reference: Apple HIG — Layout & Visual Design (respect safe margins); Fluent — App bar density.

Recommendation: Fixed brand slot: 32px icon + 16–18px title; never exceed `topbar-height - 12px`.

2. Custom CSS sprawl without token discipline

~14k lines of hand CSS with Tegel tokens mixed with one-off selectors. `MASTER.md` still contains non-Scania button examples (`#0369a1`, `border-radius: 8px`) that conflict with shipped chrome.

Reference: IBM Carbon token architecture; Fluent design tokens.

Recommendation: Three-layer tokens (primitive → semantic → component). Delete conflicting MASTER examples or regenerate from Tegel.

3. Tables are HTML grids, not enterprise data grids

TanStack Table is installed and unused. Ticket/admin tables use `min-width: 1280px` + horizontal scroll.

Reference: Carbon Data Table; Fluent Data Grid; Atlassian Table.

Recommendation: Virtualized TanStack Table with sticky headers, column visibility, density modes, keyboard nav.

4. Charts are CSS decoration

Pie/bar via CSS gradients. No Chart.js/Recharts, no data labels accessibility beyond `role="img"`.

Reference: Carbon Charts; Material charts a11y.

Recommendation: Accessible chart library + data table fallback for every visualization (Fiori pattern).

5. Light-only

Reference: Fluent theme provider; Material dynamic color; Apple Dark Mode.

Recommendation: Ship light + dark + high-contrast using Tegel modes if available; do not invent a second palette.

6. Visual hierarchy noise

Header packs search, locale, persona, notifications, Scania mark. Mobile collapses poorly relative to module count (15).

Reference: Linear / Notion – ruthless chrome reduction; Carbon header guidance.

Recommendation: Promote global search; demote locale; bind persona to authenticated identity (remove demo switcher in prod).

UX Review

Information Architecture failure

Modules are an in-memory `activeModule` switch inside one SPA. No URL per module (except opportunistic ticket deep-links). Browser

Reference: SAP Fiori Launchpad (semantic objects/intents); Atlassian URL-state filters; Next.js App Router conventions.

Recommendation: Routes like `/tickets`, `/tickets/[key]`, `/approvals`, `/admin/...` with search params for filters.

Role-as-UX vs role-as-security

Persona dropdown teaches users that identity is a costume. Docs admit visualization-only switching—then APIs still accept role par

Reference: Microsoft Entra / Fluent identity patterns; IBM security UX.

Recommendation: Remove persona switcher in production builds. Show authenticated claims. Impersonation only as audited admin f

Cognitive load

15 modules spanning requester → architecture → IT security → admin. Carbon Side Nav guidance: progressive disclosure; Fiori: rol

Recommendation: Role home + max 7 primary nav items; overflow to “More” / Launchpad groups.

Forms

New ticket modal is sophisticated domain-wise (cascading product/PRU/site) but built on manual `useState`, not RHF+Zod. Error reco

Reference: Stripe Checkout form discipline; Carbon forms; RHF+Zod industry standard.

Recommendation: Schema-first forms; shared Zod schemas between `/api/tickets` and UI.

Empty / loading / error states

Sonner toasts exist. Loading/empty coverage is uneven across admin/integrations. No systematic skeleton language.

Reference: Carbon skeleton; Fluent shimmer; Notion progressive loading.

Recommendation: Standardize `Loading`, `Empty`, `Error`, `Forbidden` primitives per module.

Search

Header ticket search is useful but not a global command palette. Atlassian/Linear users expect `■K` across tickets, people, module

Recommendation: Command palette with recent, tickets, navigation intents.

Accessibility Review

WCAG 2.2 AA posture: Partial / fragile

Area	Finding	Severity
Skip link	Present in layout	Good
Playwright axe	One home smoke (`tests/a11y/home.spec.ts`)	Insufficient
Focus management	Modals/drawers ad hoc	High
Keyb		

Next.js 16 App Router

■■ page.tsx → NexusPortal (client god object)

■■ 15 modules (functions in same file)

■■ imperative fetch → /api/*

■■ SQLite via local-database.ts

■■ optional integrations (Jira/GitLab/Graph/SMTP/AI)

Critical defects

- God component / god CSS** – violates every maintainability standard (IBM Garage, Microsoft Azure Application Architecture Guid
- Fake App Router usage** – one page; providers wrap SPA; no segment boundaries.
- QueryProvider without queries** – dead abstraction tax.
- Docs vs code** – architecture docs describe outbox/Postgres services; runtime is monolith + SQLite + partial outbox scripts.
- Duplicated integration call sites** – token-missing / error messaging repeated.

Target architecture (production)

App Router segments per domain
 /tickets, /approvals, /admin, /integrations, /tv (authZ gated)
 Server Components for read models where possible
 TanStack Query for client mutations/cache
 Zod contracts shared UI↔API
 Postgres (or managed SQL) + outbox worker
 Auth middleware (Entra / ALB OIDC) on every route
 Policy engine (RBAC/ABAC) server-side
 Module folders with colocated components/tests
 Reference: Next.js App Router best practices; Microsoft Cloud Application Architecture; Stripe API versioning discipline.

Security Review

Critical findings

SEC-01 — Client-trusted RBAC (Critical)

APIs accept `role` from query/body (`/api/tickets`, `/api/database`). Attacker sets `role=admin`.

Impact: Full data exfiltration / mutation as admin.

Reference: OWASP A01 Broken Access Control; Microsoft Identity Zero Trust.

Fix: Derive role from validated session/JWT claims only. Never accept client role for authorization.

SEC-02 — Browser-stored integration secrets (Critical)

Impact: XSS → credential theft; shared machine leakage.

Reference: OWASP A02 Cryptographic Failures / Sensitive Data Exposure; Stripe secret handling.

Fix: Server-side secret store (Key Vault / Secrets Manager); browser never sees long-lived tokens.

SEC-03 — Auth not enforced in shell (Critical)

Impact: Unauthenticated access to governance workflows (depending on network placement).

Fix: Mount auth gate; implement `/login`; fail closed.

SEC-04 — Unauthenticated `/tv` (High)

TV dashboard reads SQLite with no auth.

Impact: Sensitive KPI/ticket leakage on shared networks.

Fix: AuthZ + network allowlist + read-only service identity.

SEC-05 — Missing security headers (High)

No CSP, HSTS, X-Frame-Options/frame-ancestors, Referrer-Policy in `next.config.ts`.

Reference: OWASP Secure Headers; Microsoft SDL.

Fix: Next `headers()` with strict CSP compatible with Tegel.

SEC-06 — MSAL sessionStorage + broad Graph scopes risk (Medium)

Delegated Graph for meetings is fine if scoped; ensure least privilege and token lifetime monitoring.

SEC-07 — AI endpoint with server API key (Medium)

SEC-08 — Admin DB inspector (High)

Database API reachable with spoofed role — catastrophic with SEC-01.

Production rule: No raw DB browser in internet-facing builds without break-glass controls.

Performance Review

Risk	Evidence	Impact at 50k users
Mega client JS	43k-line client component + Tegel	Slow TTI, high memory on low-end laptops
Mega CSS	14k-line globals to all pages	Parse cost; poor caching granularity
No module code-split	All modules in one graph	Users pay for admin/Jira code on dashboard
Full ticket list in client state	Tickets loaded broadly	Does not scale; need pagination/virtualization
Re-render blast radius	Shell state drives all derived UI	Interaction jank
Unused deps	Query/Table/RHF still installed	Bundle/noise

Reference: Vercel performance guidance; Carbon performance; Linear virtualization norms.
Targets: LCP < 2.5s on mid laptop; INP < 200ms; ticket list virtualized; route-level splitting.

Component Review

Current	Verdict	Prefer	Why	Reference
Scania Tegel buttons/header	Keep	Tegel	Brand-mandated; do not replace with shadcn primary	Scania DS
Custom tables	Replace	TanStack Table + Tegel styles	Sorting, a11y, virtualization	Carbon / Fluent grids
Imperative fetch	Replace	TanStack Query	Cache, retry, dedupe, mutation lifecycle	Modern enterprise FE
Manual form state	Replace	RHF + Zod	Validation parity UI/API	Stripe / Carbon forms
CSS pie/bar	Replace	Accessible chart lib + table fallback	Legibility, a11y	Carbon Charts
Custom dialogs	Evaluate	Tegel modal or Radix Dialog	Focus trap, ESC, aria	WAI-ARIA
Icons	Keep TegelIcon	—	Consistency over Lucide unless gap	Brand
Toasts (Sonner)	Keep	—	Adequate	—
shadcn/ui wholesale	Do not	—	Conflicts with Tegel/Scania; creates dual systems	Design system integrity
Tailwind	Optional later	Only if tokenized to Tegel	Avoid utility chaos atop 14k CSS	Fluent/Carbon token first
Framer Motion	Use sparingly	—	Density 8/10 + Motion 3/10 in MASTER	Apple HIG restraint

Hard rule for this product: Prefer Tegel + Scania over shadcn aesthetics. Use headless primitives (Radix/TanStack/RHF/Zod) underneath Tegel styling—not a second visual system.

Design System Compliance

System	Compliance	Notes
Scania Tegel	Medium–High visually / Low structurally	Packages used; not fully leveraged; custom CSS fights components
IBM Carbon	Low	No Carbon; missing structured data table, notifications, tearsheet patterns
Microsoft Fluent	Low–Medium	Entra intent present but unwired; density ok; identity UX wrong
SAP Fiori	Low	No Launchpad intents; no object page template rigor
Material 3	Low	Not applicable; don't force
Apple HIG	Low–Medium	Clipping/brand margins recently failed HIG layout basics
Atlassian	Low	Ticket UX lacks URL filters, Jira-parity keyboard
Stripe	Low	Form/API clarity not Stripe-grade
Vercel	Low	Marketing polish absent (ok); App Router misuse not ok
Linear	Low	Speed/keyboard-first absent
Notion	Low	Calm empty states / blocks model absent

Competitor Comparison

```
| Dimension | Nexus today | Enterprise bar (Carbon/Fluent/Fiori/Atlassian) |
|---|---|---|
| Identity | Optional / demo personas | Mandatory SSO + claims |
| Nav | 15-item rail | Role Launchpad / progressive nav |
| Tickets | Custom list + drawer | URL addressable issue view |
| Tables | Static HTML | Virtualized, column config |
| Admin | In-SPA mega panel | Separated admin app or gated segment |
| Theming | Light only | Light/dark + high contrast |
| Docs fidelity | Ahead of code | Code matches ADR |
```

```
---
```

Enterprise Gap Analysis

vs IBM Carbon

- **Strengths:** Dense data UI intent; industrial seriousness.
- **Weaknesses:** No Carbon data table/tearsheet/notification system rigor.
- **Missing:** Structured side nav groups, batch actions, skeleton patterns, token linting.

vs Microsoft Fluent + Entra

- **Strengths:** MSAL code exists; Graph meeting feature directionally correct.
- **Weaknesses:** Auth unwired; persona switcher antithetical to Entra identity.
- **Missing:** Conditional Access awareness, MSAL React patterns, Fluent toolbar density consistency.

vs SAP Fiori

- **Strengths:** Role concepts exist in code.
- **Weaknesses:** No intent-based navigation; object pages inconsistent.
- **Missing:** Launchpad, edit/display parity, message strip standards, enterprise form templates.

vs Stripe

- **Strengths:** Real payment-adjacent? N/A. Form complexity exists.
- **Weaknesses:** Validation and API error contracts inconsistent.
- **Missing:** Schema-driven forms, impeccable empty/error copy, audit-friendly API shapes.

vs Vercel / modern Next

- **Strengths:** Next 16 + React 19.
- **Weaknesses:** SPA-in-disguise.
- **Missing:** Segment auth, streaming where useful, ISR/route caching strategy, edge middleware.

vs Linear / Notion

- **Strengths:** Operational density.
- **Weaknesses:** Keyboard-first and calm IA missing.
- **Missing:** ■K, issue deep links as first-class, optimistic UI discipline.

vs Atlassian

- **Strengths:** Jira integration ambition.
- **Weaknesses:** Second-class issue UX vs Jira itself.
- **Missing:** Filter URLs, saved views, permission scheme alignment with Jira.

vs Material / Apple

- Not primary brand systems for Scania—use only for a11y/layout lessons (touch targets, clipping, motion).

```
---
```

Top 20 Improvements

```
| # | Title | Severity | Priority | Effort | Business Impact | UX Impact |
|---|---|---|---|---|---|---|
| 1 | Enforce server-side authZ from session claims | Critical | P0 | L | Prevents admin spoofing / data breach | Trust in roles |
| 2 | Remove secrets from localStorage; use vault | Critical | P0 | L | Stops credential theft via XSS | Cleaner admin UX |
| 3 | Wire AuthProvider/AuthGate; add `/login` | Critical | P0 | M | Mandatory access control | Clear signed-in state |
| 4 | Split `NexusPortal.tsx` into domain modules | High | P0 | XL | Enables teams to ship safely | Faster iteration |
| 5 | URL-based IA (`/tickets`, `/approvals`, ...) | High | P1
```

```
[ Tegel Header: Logo | Global Search | Locale | User ]
```

```
[ Nav groups ][ Module canvas ]
```

```
[ - Work ][ Title + primary action ]
```

```
[ - Govern ][ Filters (URL synced) ]
```

```
[ - Admin ][ Main view / table / object page ]
```

```
Spacing: 8-pt grid; header 56px; nav expanded 272px / collapsed 56px (already close).
```

```
Typography: Scania Sans Headline for page titles 20-24px; body 14px; meta 12px.
```

```
Motion: 150-200ms opacity/translate only; respect reduced motion.
```

```
Components: Tegel nav + TanStack Table + Sonner; Radix Dialog only if Tegel modal lacks focus trap.
```

Issue B — Identity

```
IBM: No demo role switcher in prod.
```

```
Microsoft: MSAL + account picker; roles from App Roles/Groups.
```

```
Stripe: Single clear signed-in actor.
```

```
Best: Wire Entra; show name/email/roles from claims; audited impersonation only.
```

Issue C – Data density tables

IBM Carbon Data Table patterns win for enterprise.

Implementation: TanStack Table + Tegel tags/buttons; sticky header; row actions in menu; bulk actions bar.

Implementation Plan (exact files)

```
| Workstream | Files / actions |
|---|---|
| Auth wiring | `src/app/layout.tsx`, add `src/app/login/page.tsx`, use `AuthProvider.tsx`, `AuthGate.tsx` |
| API authZ | `src/app/api/tickets/route.ts`, `src/app/api/database/route.ts`, `src/app/api/**`, `src/lib/auth/*` |
| Secrets | Remove writes in `NexusPortal.tsx` (~localStorage secrets); server vault module under `src/lib/secrets/` |
| Split UI | Extract from `NexusPortal.tsx` → `src/components/nexus/{dashboard,tickets,admin,integrations,escalations}/` |
| CSS | Split `globals.css` → `styles/{tokens,shell,tickets,admin}.css` or CSS modules |
| Data | Wire `QueryProvider` usage; ticket hooks in `src/lib/queries/` |
| Forms | `src/lib/schemas/ticket.ts` (Zod) + RHF forms |
| Headers | `next.config.ts` `headers()` |
| TV lock | `src/app/tv/page.tsx` + middleware |
| Tests | Expand `tests/` beyond `tests/a11y/home.spec.ts` |
```

Do not introduce a parallel shadcn visual theme. Headless libraries only.

Final Verdict

Nexus Support is a capable Scania-skinned internal governance console trapped inside a prototype architecture.

It looks more “enterprise” than most startup MVPs because Tegel and navy chrome do real brand work. It fails enterprise production

Ship decision: **No** for 50,000 users.

Pilot decision: Conditional yes on a closed network **only after** P0 security fixes (auth gate, server authZ, secret removal,

Investment decision: Yes—domain richness is valuable—if leadership funds a 1–3 month platformization program before feature ex

Appendix A – Score Summary Table

Category	Current Score	Target Score	Estimated Time to Target
Visual Design	6.0	8.5	3–4 weeks
UX	5.0	8.5	6–8 weeks
UI	5.5	8.5	4–6 weeks
Navigation	5.5	8.5	3–5 weeks
Information Architecture	4.5	8.5	6–8 weeks
Accessibility	5.0	9.0	6–10 weeks
Performance	3.5	8.5	6–8 weeks